

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – VIVA QUESTIONS

Course: Ethical Hacking	Code: ITA1408	CO: CO5
Duration:	Total Marks: 100	Name : S Deepadharshan Reg No :192472046

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Code of Conduct:

I S Deepadharshan (192472046) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: S Deepadharshan

1. How would you evaluate the security posture of a Windows system after identifying multiple open services?

Answer:

I would first identify all open ports and the services running on them. Then I would check the service versions, configurations, authentication mechanisms, and known vulnerabilities. I would determine whether the services are necessary and whether they are exposed to untrusted networks. Unnecessary services should be disabled, vulnerable services should be patched, and firewall rules should restrict unnecessary access.

2. Which factors would you consider when choosing a hacking tool for Windows vulnerability assessment, and why?

Answer:

I would consider the assessment objective, Windows version, vulnerability type, tool reliability, compatibility, accuracy, and safety. The tool should be suitable for authorized security testing and should provide useful evidence without causing unnecessary damage. I would select a tool based on the specific service or vulnerability being assessed.

3. How would you evaluate the security risk associated with an exposed RPC service?

Answer:

I would identify the RPC service, its version, configuration, and network exposure. I would check for known vulnerabilities and determine whether authentication and access controls are properly implemented. An exposed and vulnerable RPC service can potentially allow unauthorized access or remote code execution. Unnecessary RPC exposure should therefore be restricted using firewalls and network controls.

4. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?

Answer:

Windows Null Sessions allow anonymous users to access certain network resources without valid credentials. This can expose information such as usernames, shares, and system details. I would

assess what information can be obtained anonymously and determine whether it can assist further attacks. Anonymous access should be disabled where it is not required.

5. A Windows shared folder allows unauthorized users to access sensitive files. How would you evaluate the severity of this vulnerability?

Answer:

I would examine the sensitivity of the files, the number of unauthorized users, and the permissions provided. Read-only access to sensitive information is serious, while modification or deletion permissions create an even greater risk. I would assess the confidentiality and integrity impact and recommend proper NTFS and share permissions with appropriate authentication.

6. How would you distinguish between a vulnerable Windows service and a misconfigured Windows service during security testing?

Answer:

A vulnerable service contains a software weakness, such as an outdated version with a known vulnerability. A misconfigured service uses software that may be secure but has incorrect settings, excessive permissions, or unnecessary exposure. I would check the software version, known vulnerabilities, configuration, permissions, and network exposure to determine the cause.

7. How would you evaluate the effectiveness of information-gathering techniques against a Windows target?

Answer:

I would compare the information gathered with the actual attack surface of the authorized Windows system. Important information includes IP addresses, open ports, services, versions, shares, usernames, and operating-system details. Effective information gathering should identify important attack surfaces while avoiding unnecessary interaction with the target.

8. If a Windows vulnerability can be exploited but requires local access, how would you classify its security impact compared with a remotely exploitable vulnerability?

Answer:

A remotely exploitable vulnerability generally has a higher initial security impact because an attacker does not need existing access to the system. A local vulnerability requires prior access, reducing its attack reach. However, a local vulnerability can still be highly serious if it allows privilege escalation from a normal user to administrator-level access.

9. How would you evaluate the security risks of unconnected or unnecessary services running on a Linux system?

Answer:

I would identify all running services and determine whether each service is required. I would examine their listening ports, versions, configurations, privileges, and known vulnerabilities. Unnecessary services increase the system's attack surface and may provide additional entry points for attackers. They should be disabled or restricted if they are not required.

10. Why are rhosts and hosts.equiv considered security risks in Linux? How would you evaluate their impact on system security?

Answer:

`rhosts` and `hosts.equiv` can establish trust between systems without requiring strong authentication. If a trusted system is compromised, an attacker may potentially use the trust relationship to gain unauthorized access. I would inspect these files, identify trusted hosts and accounts, and remove unnecessary trust relationships.

11. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?

Answer:

I would examine the NFS export configuration and identify which directories are shared and which clients are allowed to access them. I would check whether sensitive directories are exported with excessive read or write permissions. I would also verify whether unauthorized users can access or modify the files. Access should be restricted to trusted systems with appropriate permissions.

12. A Linux file has incorrect permissions that allow unauthorized modification. How would you evaluate the resulting security risk?

Answer:

I would check the file owner, group, permission bits, and users who can modify the file. If an unauthorized user can modify a critical executable or configuration file, the risk can be high because it may lead to privilege escalation or system compromise. I would correct the permissions using the principle of least privilege.

13. How would you compare the security impact of weak file permissions with an unpatched Linux vulnerability?

Answer:

Both can create serious security risks, but their impact depends on exploitability and the affected resource. Weak permissions may directly allow unauthorized access or modification, while an unpatched vulnerability may provide a larger attack path depending on its severity. I would compare exposure, privileges required, exploitability, affected resources, and potential confidentiality, integrity, and availability impact.

14. How would you evaluate whether a buffer overflow vulnerability in a Linux application is practically exploitable?

Answer:

I would first identify the affected application and confirm the vulnerability. Then I would check security protections such as ASLR, DEP/NX, stack canaries, and compiler protections. In an authorized environment, I would use a controlled proof of concept to determine whether the vulnerability can reliably affect the application's execution. The findings would then be documented and remediation recommended.

15. Which factors would you consider before selecting an exploitation technique for a Linux vulnerability?

Answer:

I would consider the vulnerability type, software version, operating-system version, required privileges, network accessibility, security controls, exploit reliability, and potential impact. The technique should be appropriate for the authorized assessment and should minimize disruption. Where possible, a safe proof of concept should be preferred instead of unnecessary full exploitation.

16. How would you evaluate the security of a messaging application that stores user credentials or messages insecurely?

Answer:

I would examine how credentials and messages are stored and transmitted. Passwords should not be stored in plaintext and should use secure password hashing. Sensitive messages should be protected using appropriate encryption. I would also check authentication, session management,

access controls, and local storage. Insecure storage can lead to credential theft, message disclosure, and account compromise.

17. A web application is vulnerable to SQL injection. How would you evaluate the severity of this vulnerability and its possible consequences?

Answer:

SQL injection can be a high or critical vulnerability because an attacker may manipulate database queries through application input. Depending on the database privileges, it may allow unauthorized access, modification, or deletion of data. I would evaluate exploitability, affected data, privileges, exposure, and business impact. Parameterized queries and proper input handling should be used for prevention.

18. How would you determine whether a web application vulnerability represents a critical security risk or a low-risk finding?

Answer:

I would consider exploitability, attack complexity, privileges required, exposure, affected assets, and the impact on confidentiality, integrity, and availability. A remotely exploitable vulnerability that exposes sensitive information or provides administrative access would generally be critical. A difficult-to-exploit issue with minimal impact may be considered low risk.

19. How would you evaluate the security of a mobile application using a tool such as MobSF?

Answer:

I would use MobSF, or Mobile Security Framework, to perform static and, where appropriate, dynamic security analysis. I would review findings related to permissions, insecure storage, hardcoded secrets, cryptography, exported components, network security, and application configuration. Important findings would be validated, assigned a severity level, and provided with remediation recommendations.

20. A mobile application requests unnecessary permissions such as contacts, microphone, and location. How would you evaluate the associated security risk?

Answer:

I would compare the requested permissions with the actual functionality of the application. Unnecessary access to contacts, microphone, or location can expose sensitive user information. I would determine whether each permission is justified and how the collected data is used and protected. Unnecessary permissions should be removed to reduce privacy and security risks.

21. How would you evaluate the risk of hardcoded API keys or passwords discovered during mobile application analysis?

Answer:

Hardcoded credentials are a security risk because attackers may extract them from the application package or reverse-engineered code. I would determine what resources the credentials provide access to and what privileges they have. Keys providing access to sensitive or production services represent a higher risk. Secrets should be securely managed outside the application.

22. If the same vulnerability is found in both a web application and a mobile application, how would you compare their security impact?

Answer:

I would compare their exposure, affected data, authentication requirements, exploitability, privileges, and number of affected users. The same vulnerability may have different consequences depending on the platform and architecture. Therefore, severity should be

determined based on the actual impact and attack conditions rather than simply the application type.

23. How would you select appropriate hacking tools for assessing Windows, Linux, web, and mobile applications?

Answer:

I would first identify the target technology and assessment objective. For Windows and Linux, tools such as Nmap and vulnerability scanners can be used for authorized assessment. For web applications, tools such as Burp Suite and OWASP ZAP are useful. For mobile applications, MobSF and other static or dynamic analysis tools can be used. Tool selection should consider reliability, compatibility, safety, and the specific vulnerability being tested.

24. After performing vulnerability exploitation, how would you evaluate whether the exploitation technique actually demonstrates a significant security weakness?

Answer:

I would verify that the vulnerability is genuine and determine what level of access or control was obtained. I would evaluate its effect on confidentiality, integrity, and availability, along with authentication requirements and exploit reliability. Evidence such as logs, screenshots, and controlled test results should be collected. The final finding should clearly explain the impact and recommended remediation.

25. You have identified vulnerabilities in Windows, Linux, messaging, web, and mobile applications. How would you prioritize them and prepare a professional security report?

Answer:

I would prioritize vulnerabilities according to severity, exploitability, exposure, affected assets, privileges required, and business impact. Critical vulnerabilities that are remotely exploitable or affect sensitive systems should receive the highest priority.

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Problem Context	20	Clearly understands the security problem and accurately identifies vulnerabilities, risks, and requirements	Good understanding of the security problem with minor gaps	Basic understanding; some security requirements or vulnerabilities are unclear	Poor understanding or misinterpretation of the security problem	
Application of Concepts	30	Accurately applies appropriate ethical hacking concepts, tools, and exploitation techniques to analyze complex security	Applies relevant security concepts and tools correctly with minor errors	Applies basic concepts with limited accuracy or tool selection	Fails to apply appropriate security concepts or tools	

		problems				
Problem Solving Approach	20	Demonstrate s a logical, well structured, systematic, and efficient approach to identifying and evaluating security weaknesses	Mostly logical and systematic approach with minor gaps	Basic approach with some inconsistencies in vulnerability analysis	Illogical, unclear, or inappropriate approach to solving the security problem	

Accuracy of Solution	20	Provides a completely correct security analysis with appropriate justification, evidence, and suitable prevention	Mostly correct analysis with minor errors or gaps	Partially correct analysis with limited justification	Incorrect or incomplete security analysis	
Clarity	10	techniques Provides clear, well-organized, technically sound, and properly explained responses using appropriate security	Understandable response with minor clarity or terminology issues	Limited clarity and explanation; uses technical terms inconsistently	Poorly presented, unclear, and difficult to understand	
Total	100	terminology				/100